Vulnerability Assessment Report for preview.owasp-juice.shop

Refilwe Mzwakali
17 April 2026

Table of Contents

Table of contents..... .2
Executive Summary..... 3
Tools used..... 4
Methodology.....5
Risk Summary & Table..... 6
Risks & Observations (severity)..... 7
Assessment findings..... 8
1. FTP Service exposure..... 8 - 9
2. Load balancer exposure..... 10
3. Service version disclosure..... 11-12
4. Content-Security-Policy.....13-14
5. HTTP Strict-Transport-Security..... 15
6. Cross-domain Misconfiguration...16-17
7.Timestamp Disclosure..... 18
8. X-Frame-Options Present..... 19
9. X-Content-Type-Options Present.....20
10. No cookies detected 21
11. Information Disclosure..... 22
12. Modern Web application..... 23
Conclusion..... .. 24

Executive Summary

The application was assessed using passive security testing techniques, including network scanning, browser inspection, and automated vulnerability analysis. Several security misconfigurations were identified, including missing security headers, exposed services, and cross-domain weaknesses. While no critical vulnerabilities were exploited, these issues increase the risk of attack and should be addressed to improve overall security.

Tools used:

- Nmap - Network and service analysis
- Browser DevTools - Security headers & cookies
- OWASP ZAP - Passive vulnerability scanning
- Canva - Report design

Methodology

- Selected a public test Web application
- Performed read-only analysis
- Identified exposed services
- Analysed security headers
- Conducted passive vulnerability scan
- Documented findings and risks

Risk Summary

Risks identified during the assessment are classified based on their potential impact on confidentiality, integrity, and availability of the application, as well as the likelihood of exploitation.

The following risks were used:

- Medium/Low: Applied to security issues that may introduce different levels of exposure or exploitation risk to the application and its users.
- Informational: Applied to observations that do not present as direct security risks but are recorded f9ir completeness and to provide context.

Risk level	Description
Medium	Indicates a security issue that could be exploited under certain conditions and may have a moderate impact on the application and its users.
Low	Indicates a minor security issue with limited impact or low likelihood of exploitation, but still considered a deviation from efficiency.
Informational	Indicates observations that do not present a direct security risk but are recorded for context and further awareness.

Risks and observations

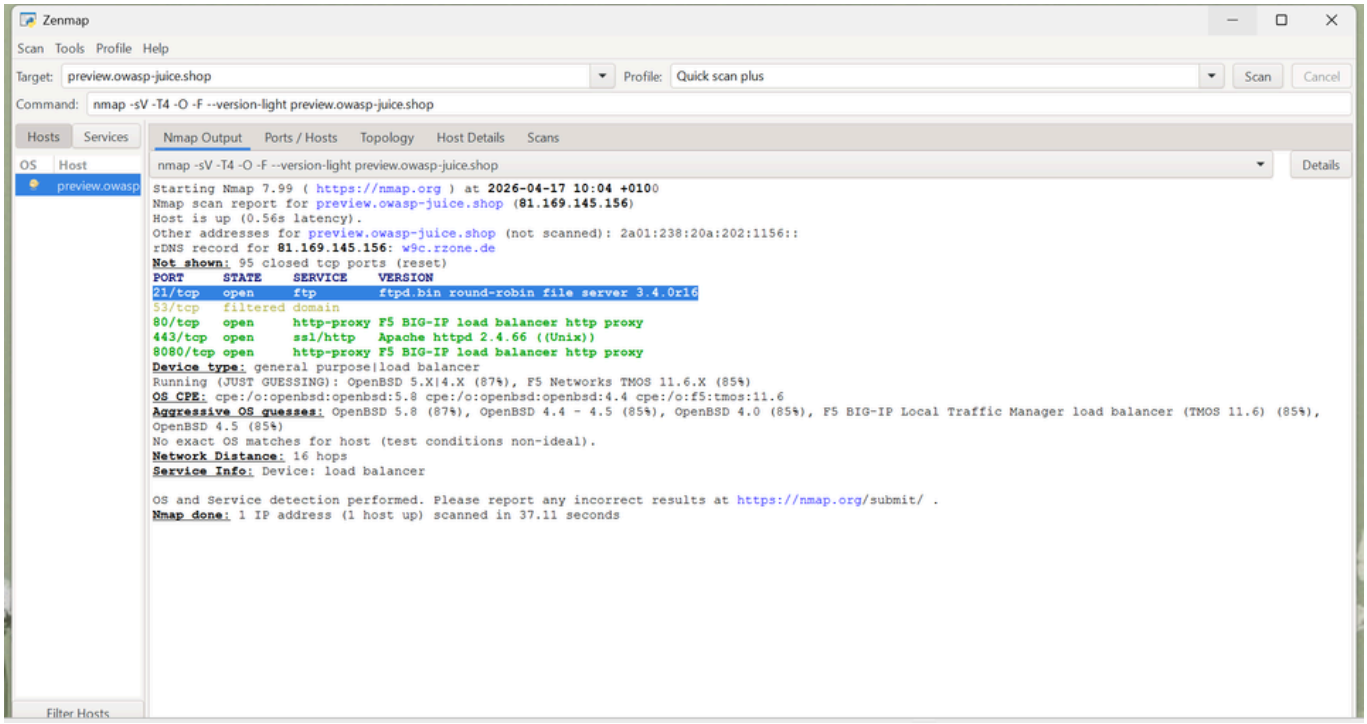
Vulnerability/ Observation	Severity
1. Exposed Services and outdated components	Medium
2. Load balancer exposure	Medium
3. Service version disclosure	Low to Medium
4. Missing Content-Security-Policy	Medium
5. Missing HTTP-Strict-Transport-Security	Medium
6. Cross-domain Misconfiguration	Medium
7. Timestamp Disclosure	Low
8. X-Frame-Options	Informational
9. X-Content-Type-Options	Informational
10. No cookies detected	Informational
11. Information Disclosure	Informational
12. Modern Web application	Informational

Assessment findings

1) FTP service exposed (open port 21)

Description/ Issue	FTP (File transfer protocol) is publicly accessible through the application https://preview.owasp-juice.shop/#/. FTP is an old protocol and often transmits data in plaintext, the structure can be changed, and it is not needed for modern Web apps.
Impact	Attackers may exploit weak configuration or use it as an entry point.
Risk level	Medium

Proof of Concept: 21/tcp open ftp ftpd.bin round-Robin file server 3.4.0r16



Recommendations:

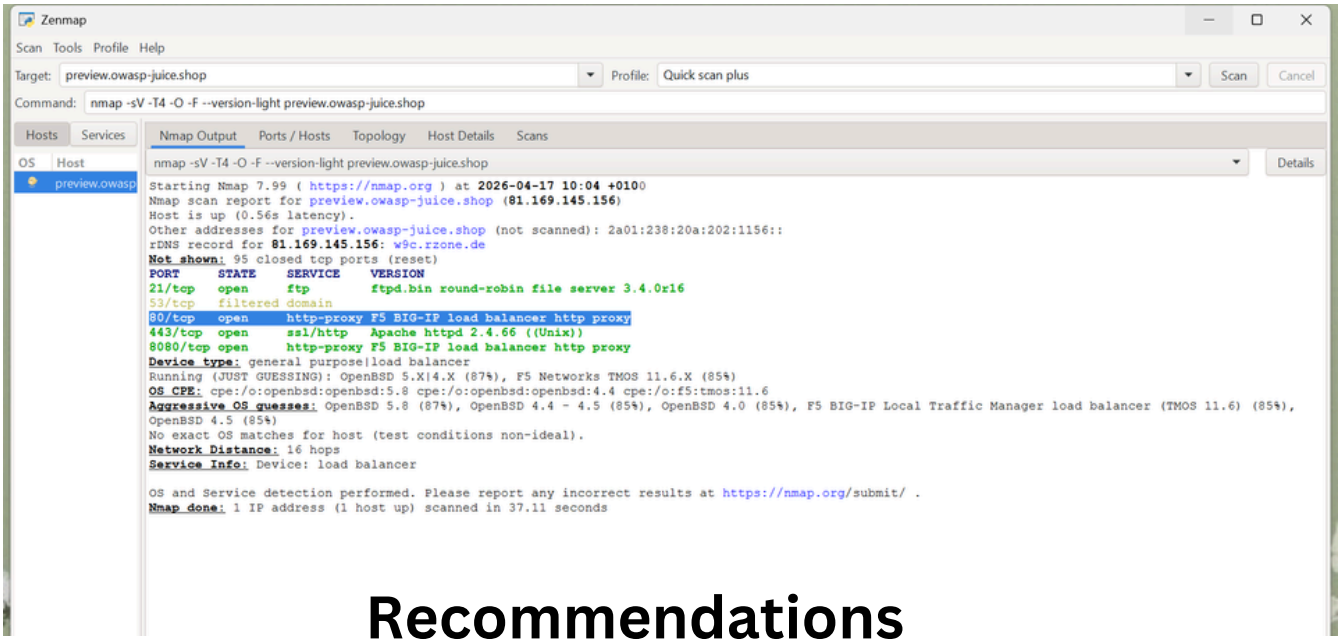
- Disable FTP if not required
- Replace with SFTP (secure file transfer)

- Restrict access via firewall

2) Multiple Proxy/ Load balancer exposure

Description/Issue	80/tcp open http-proxy F5 BIG-IP 8080/tcp open http-proxy F5 BIG-IP The internal infrastructure is exposed publicly, and the network infrastructure components are identifiable from external scanning.
Impact	Attackers can fingerprint (method of identifying and tracking devices by collecting unique attributes such as hardware configurations, software versions, and network details) infrastructure components. They can search for known vulnerabilities that affect the systems and identify specific technologies in use.
Risk level	Medium

Proof of Concept:



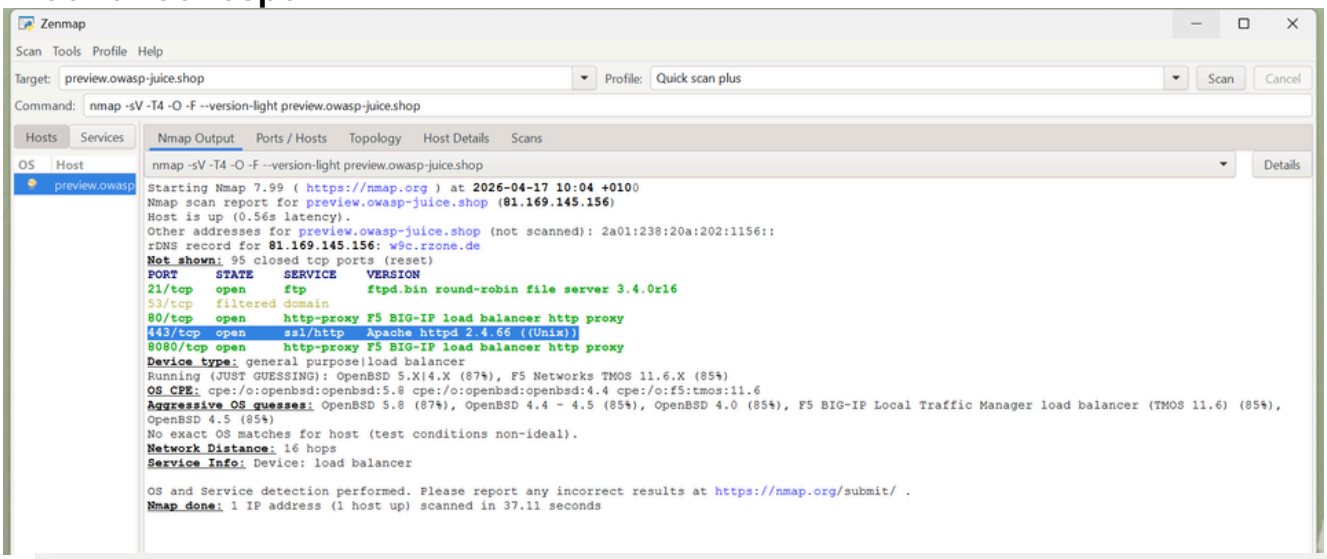
Recommendations

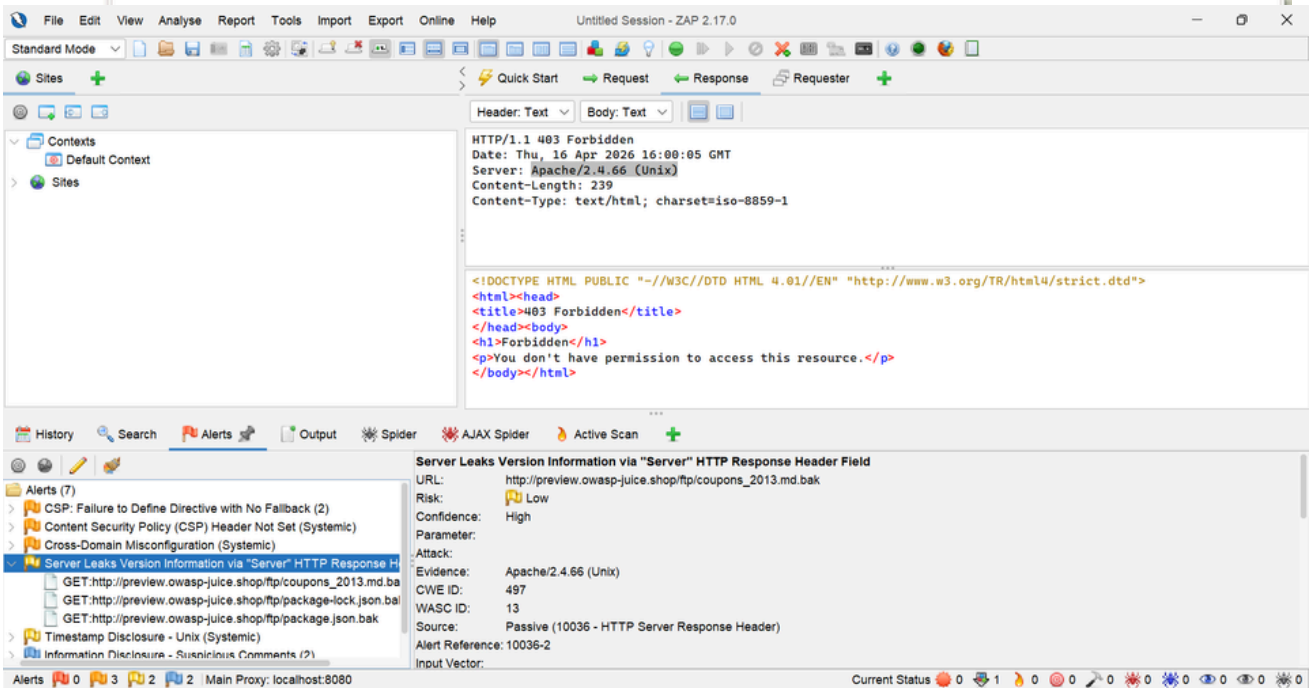
- Hide internal proxy details
- Restrict access to management interfaces
- Regularly apply security patches to infrastructure devices.

3. Service version disclosure (Apache Web server 2.4.66)

Description/Issue	Open port 443. The server reveals its exact software version.
Impact	Version exposure allows attackers to identify known vulnerabilities associated with that version and plan more targeted attacks.
Risk level	Low to Medium

Proof of Concept:





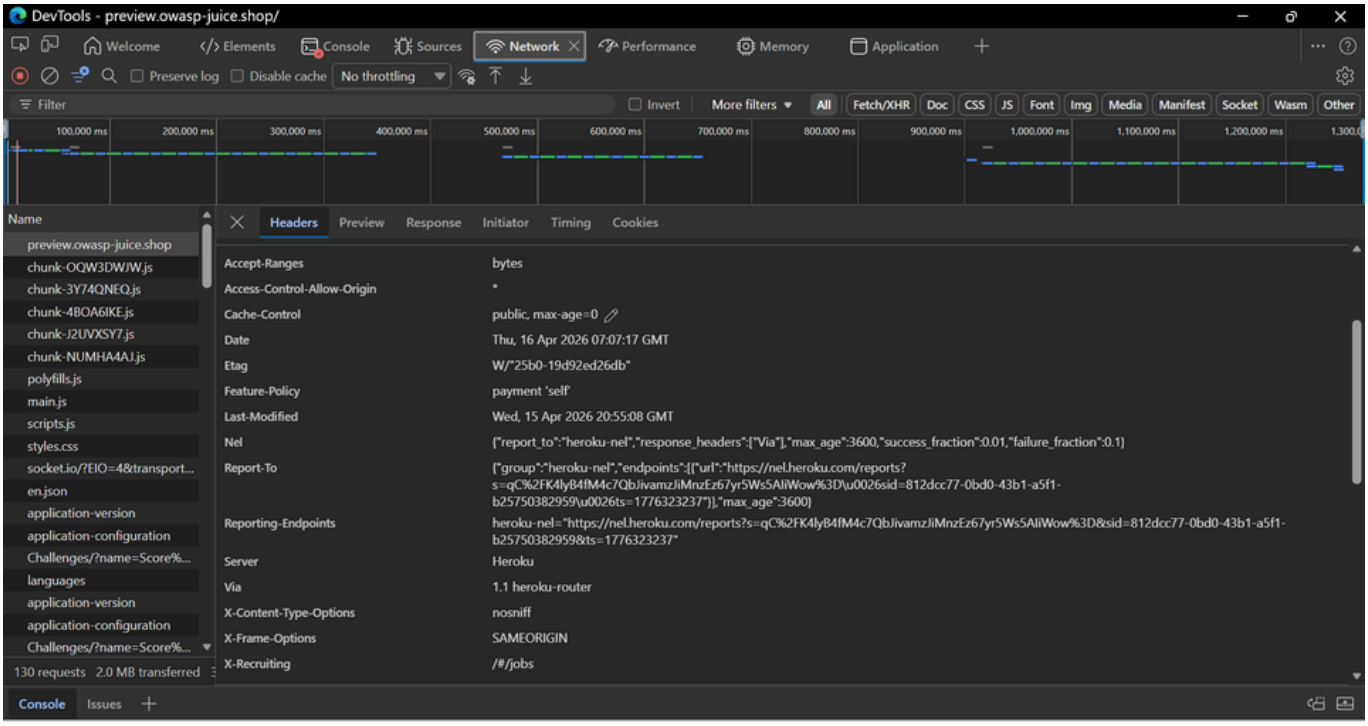
Recommendations

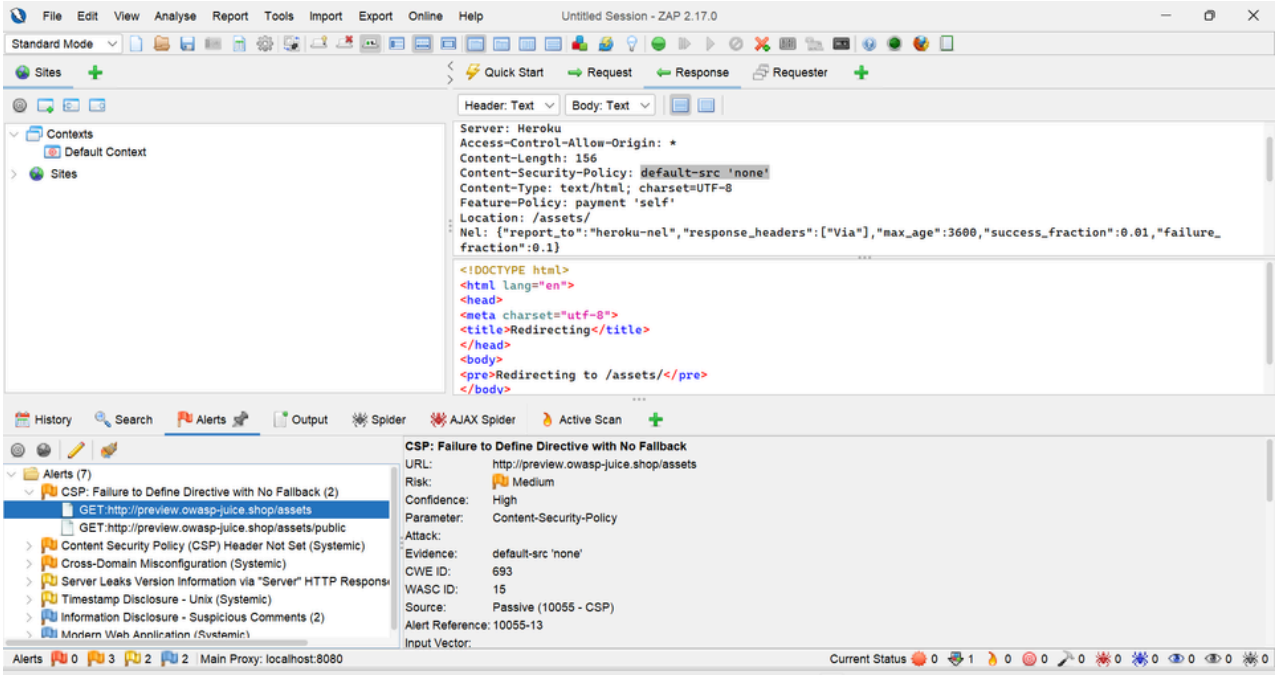
- Hide server version headers
  -ServerTokens Prod
  -ServerSignature Off
- Keep software updated with latest security patches

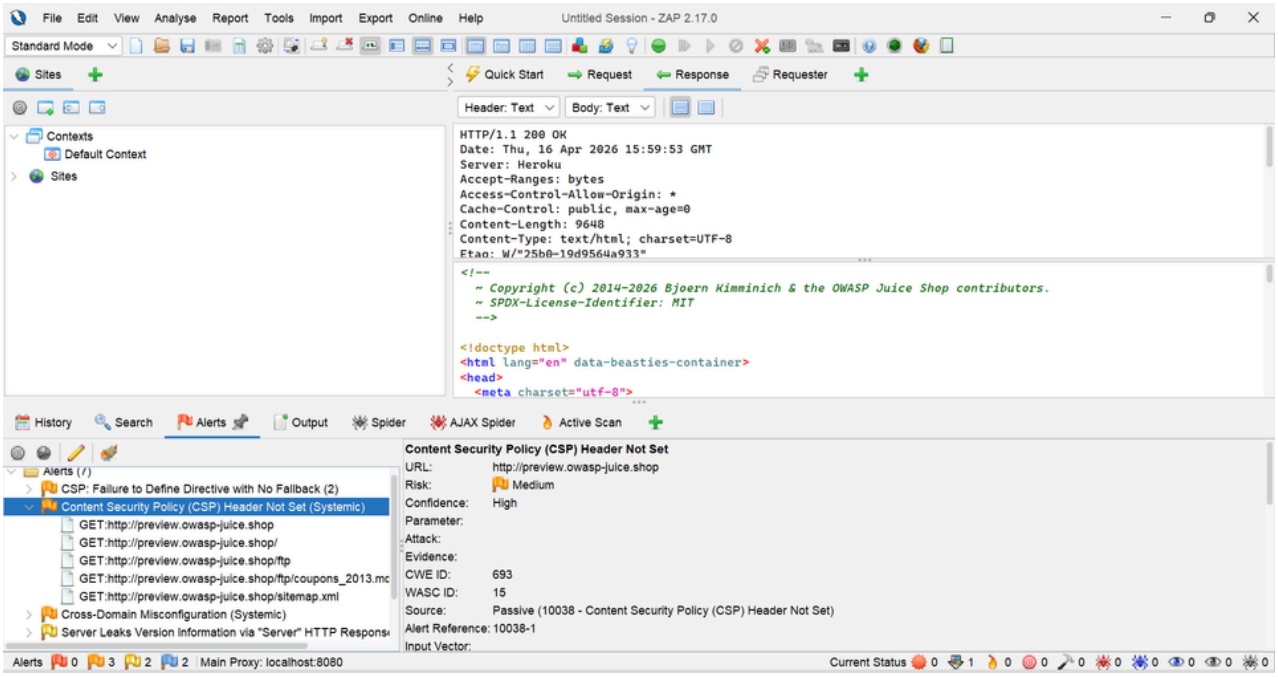
4. Missing Content-Security-Policy (CSP)

Description/Issue	Browser is not restricted in what it can load (scripts, images, etc.). This increases the risk of XSS (cross site scripting) attacks. XSS: a client-side injection vulnerability that allows attackers to execute malicious scripts in a victim's browser by exploiting insecure handling of user-supplied data)
Impact	It enables attackers to impersonate users, steal sensitive data through cookies and session tokens, or manipulate site content.
Risk level	Medium

Proof of Concept:







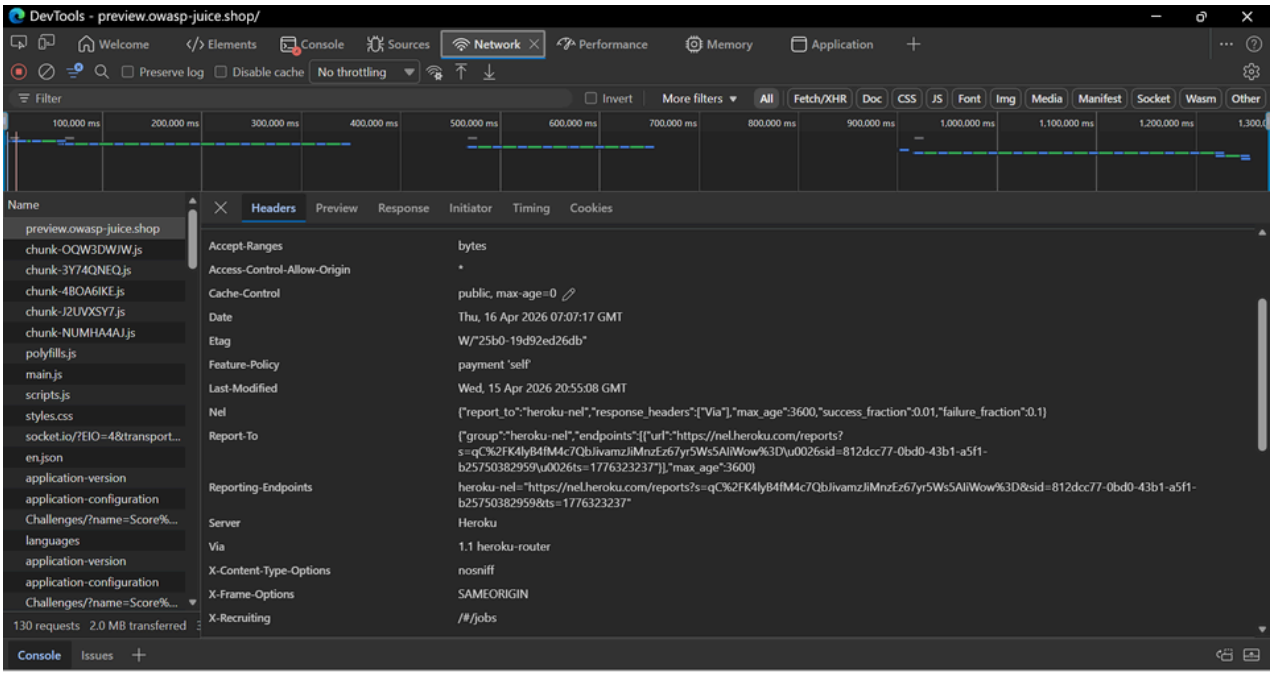
Recommendations:

- Implement CSP header and only allow trusted domains for scripts and content.

5. Missing HSTS (HTTP Strict-Transport-Security)

Description/Issue	The browser is not forced to use HTTPS. This opens doors to downgrade attacks.
Impact	Users could be directed to insecure HTTPS versions of the site, exposing them to potential interception or manipulation of data.
Risk level	Medium

Proof of Concept



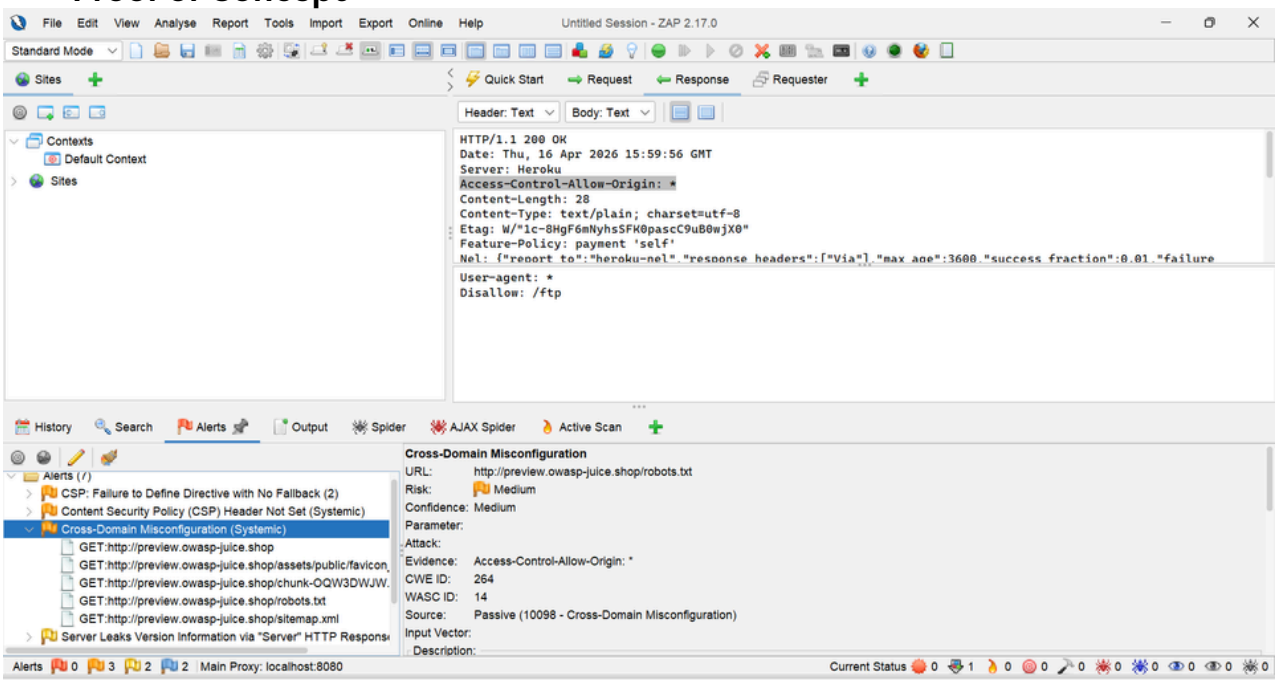
Recommendations:

- Enforce HTTPS across all user sessions by enabling HSTS on the Web platform.

6. Cross-domain Misconfiguration

Description/ Issue	Web browser data may be possible, dute to a Cross Origin Resource Sharing (CORS) misconfiguration on the Web server. This misconfiguration allows cross-domain read requests from arbitrary third party domains, using unauthenticated APIs (Application programming interface) on this domain. However, Web browser implementations do not allow these third parties to read responses from authenticated APIs, which reduces the risk.
Impact	An attacker could use this misconfiguration to access data that is available in an unauthenticated manner.
Risk level	Medium

Proof of Concept



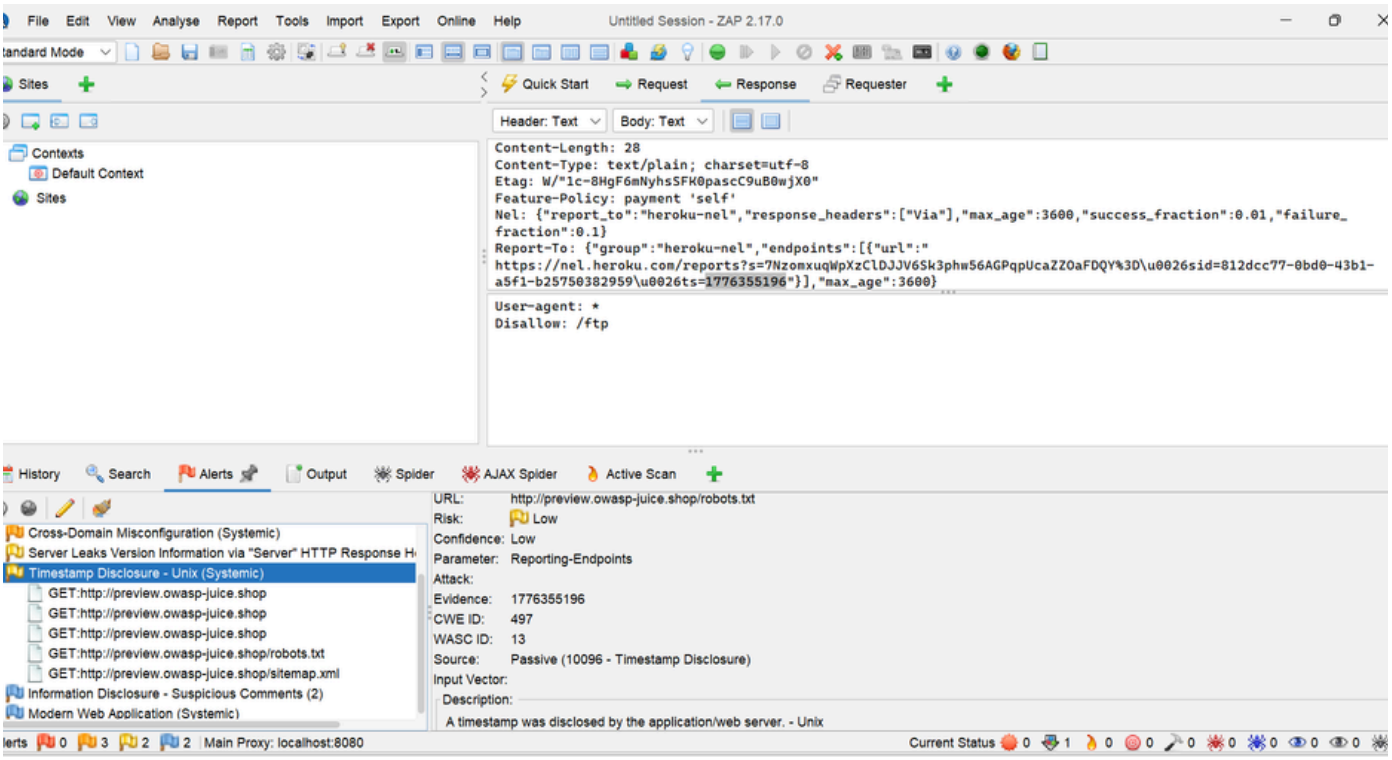
Recommendations:

- Ensure that sensitive data is not available in an unauthenticated manner.
- Configure the "Access-Control-Allow-Origin" HTTP header to a more restrictive set of domains, or remove CORS headers entirely, to allow the Web browser to enforce the Same Origin Policy in a more restrictive manner.

7. Timestamp Disclosure

Description/ Issue	A timestamp was disclosed by the application/ Web server--Unix.
Impact	Timestamp disclosure may provide attackers with system timing information that can aid in executing time-based attacks.
Risk level	Low

Proof of Concept



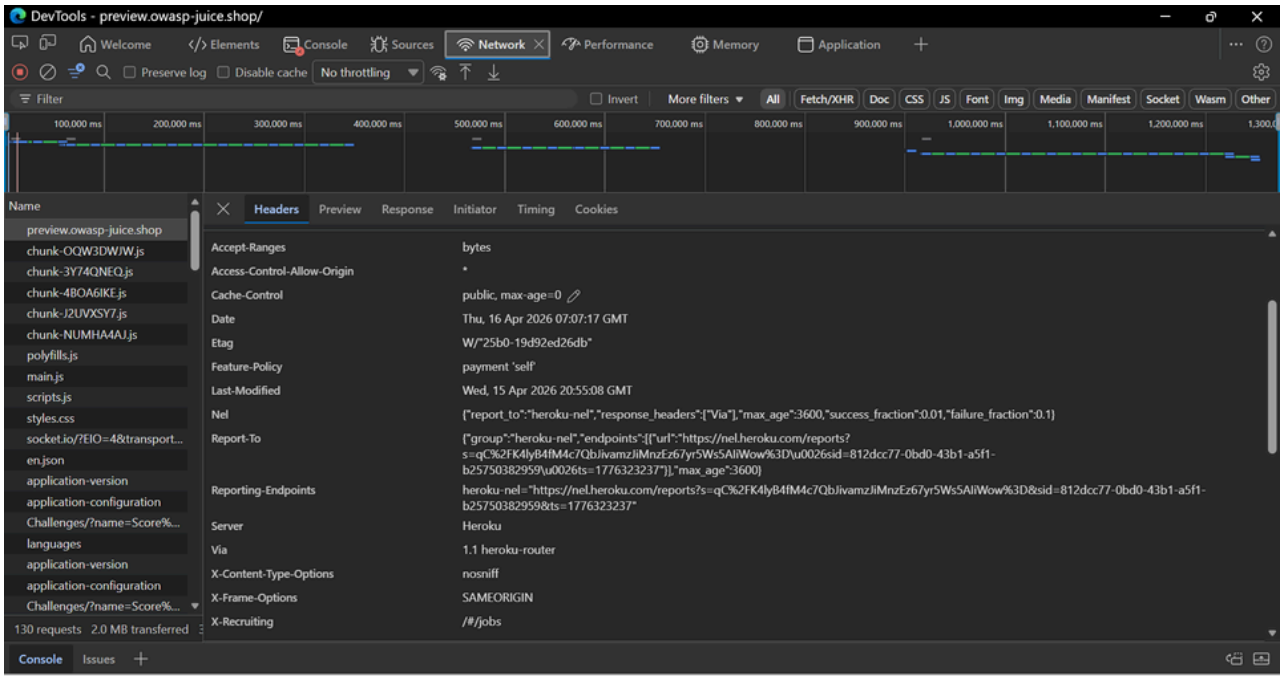
Recommendations:

- Manually confirm that the timestamp is not sensitive, and the data cannot be aggregated to disclose exploitable patterns

8. X-Frame-Options present

Type	Informational
Description	It prevents click jacking (an attack where users are tricked into clicking hidden elements, causing unintended actions, leading to data integrity and account security risks).

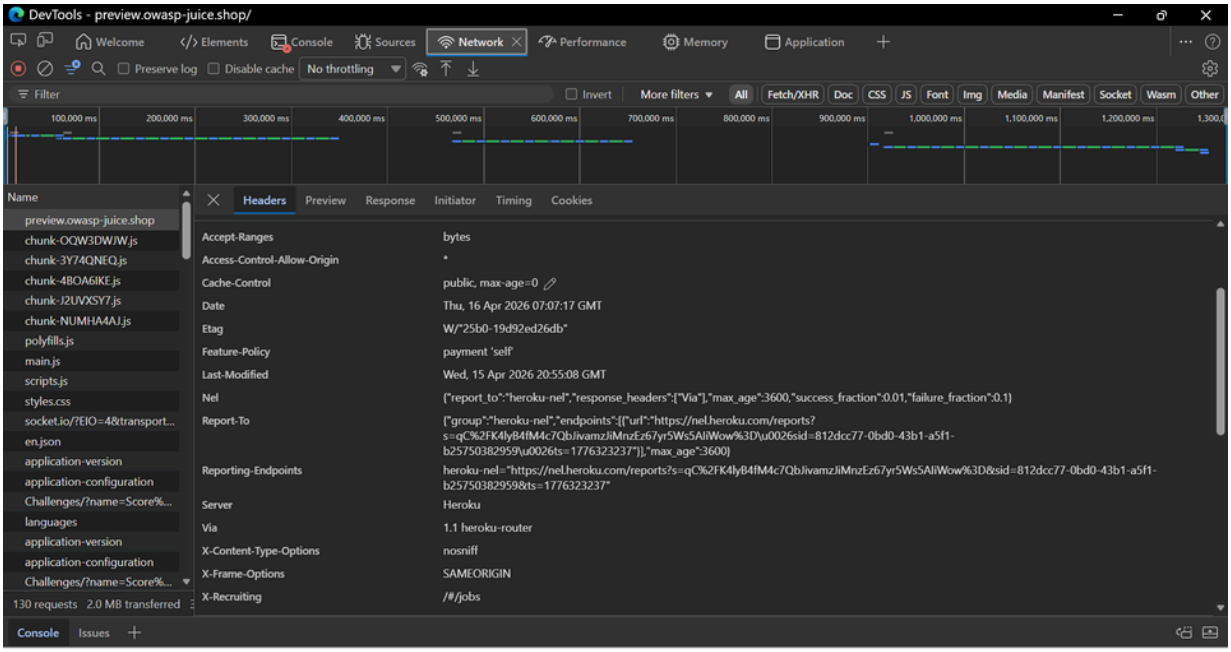
Proof of Concept



9. X-Content-Type-Options Present

Type	Informational
Description	X-Content-Type-Options prevent browsers from guessing and incorrectly interpretiting file types, reducing the risk of content-based attacks such as XSS.

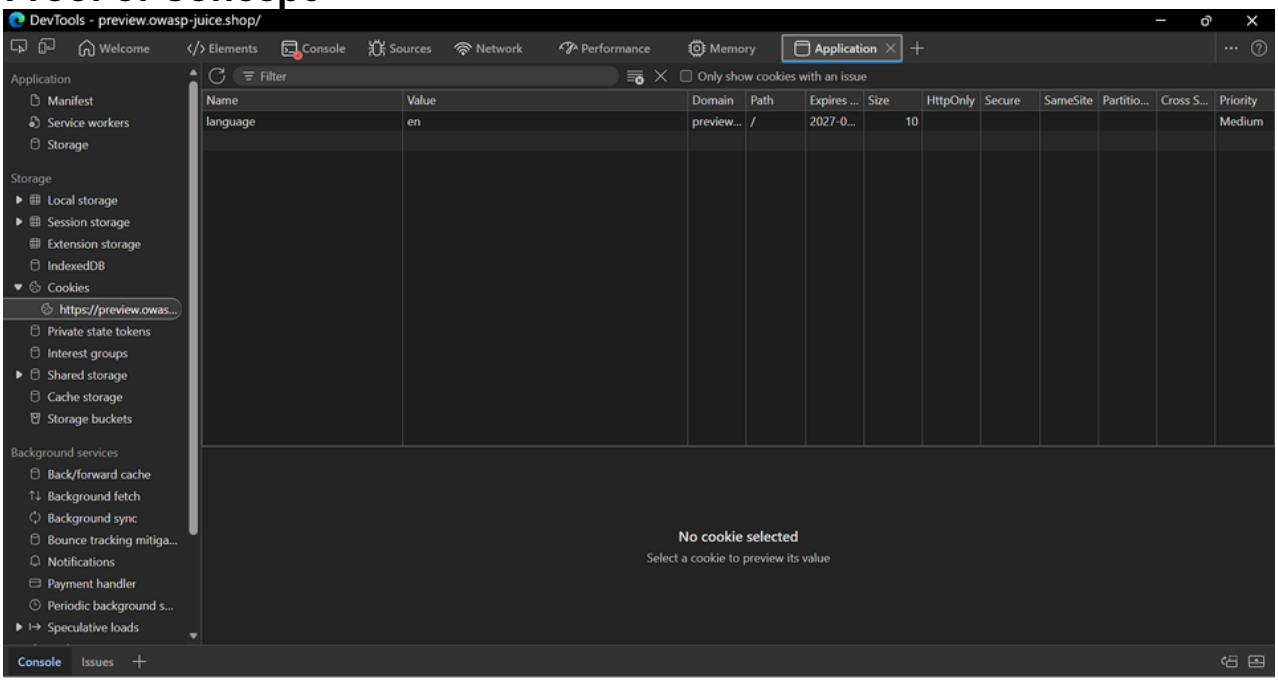
Proof of Concept



10. No cookies detected

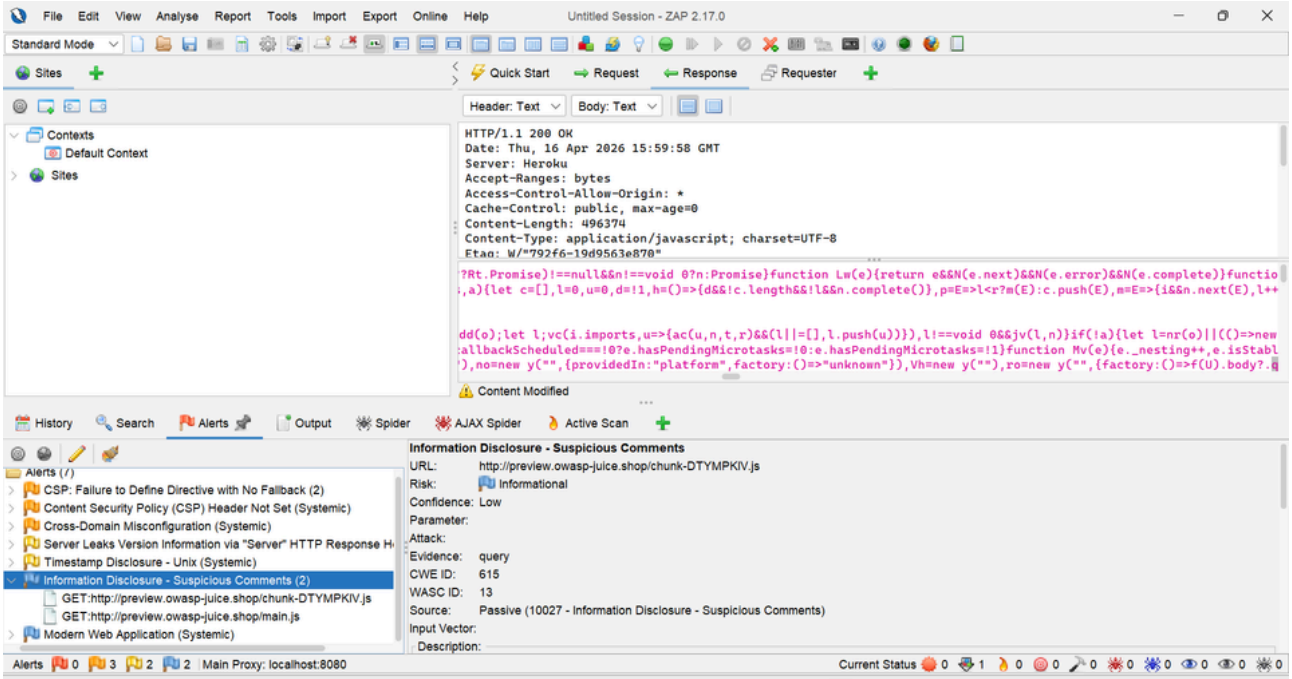
Type	Informational
Description	No cookies were present in browser for the application (preview.owasp-juice.shop) during testing, indicating that the application may not be using a cookie-based session management.

Proof of Concept



11. Information Disclosure

Type	Informational
Description	The response appears to contain suspicious comments which may help attackers better understand the system and plan targeted attacks.



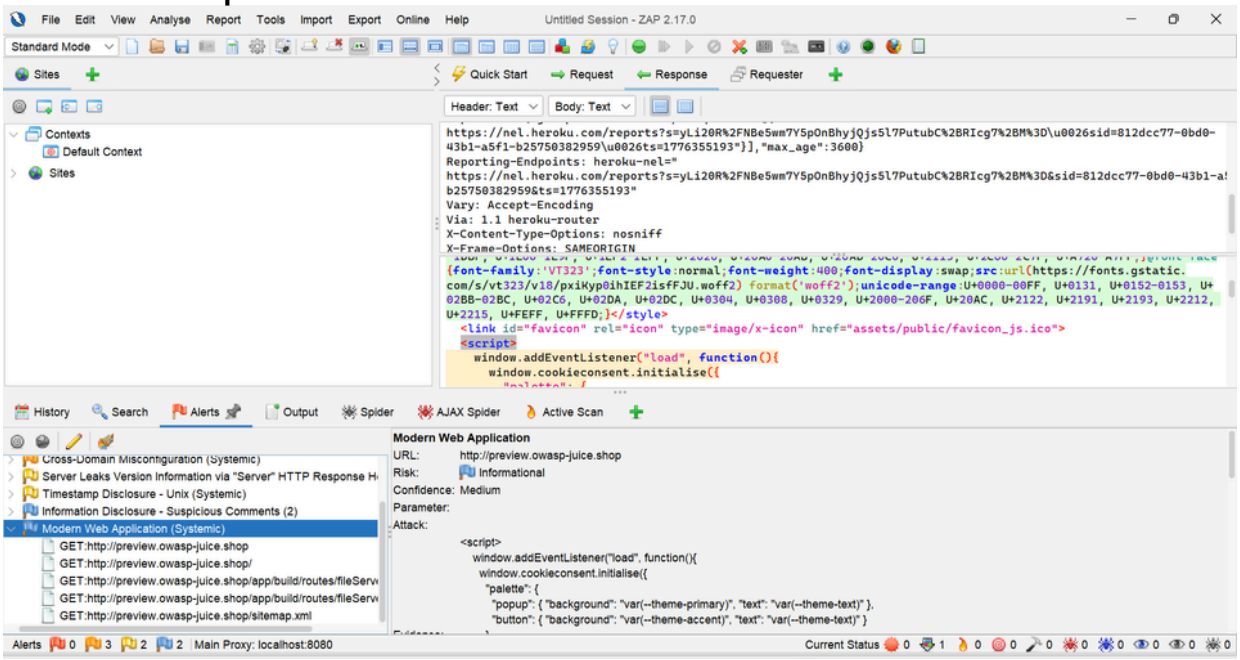
Recommendations:

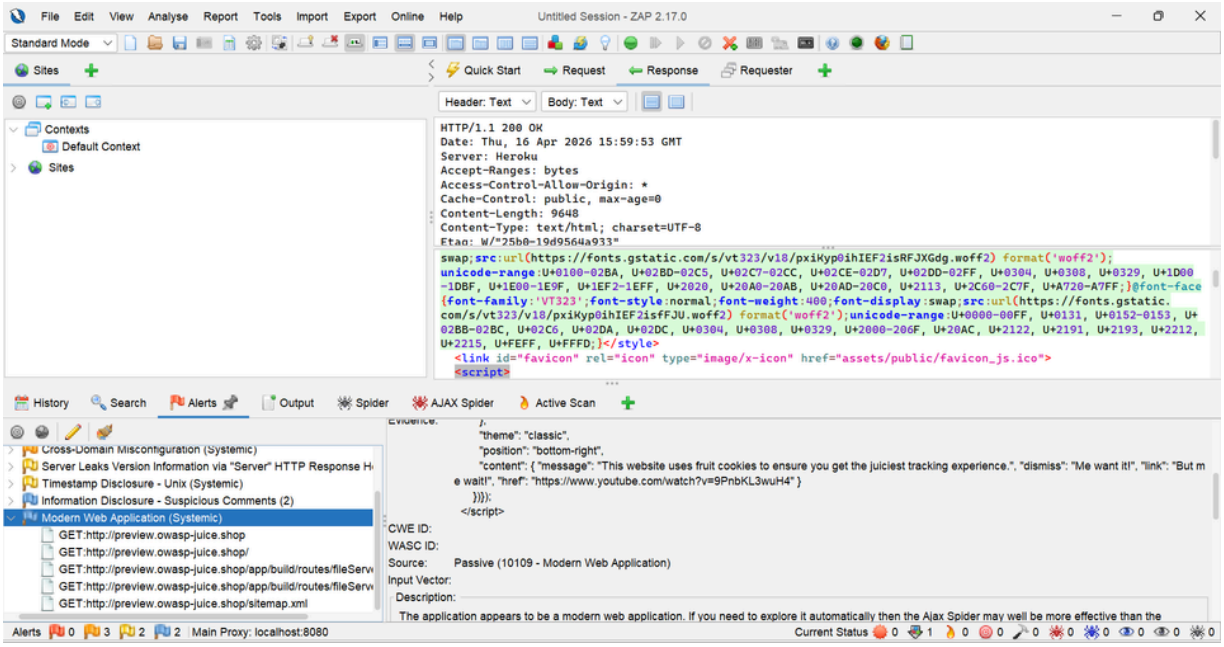
- Remove all comments that return information that may help an attacker and fix any underlying problems they refer to.

12. Modern Web application

Type	Informational
Description	The application was identified as modern Web application, likely using client-side rendering and/or API-driven structure. This is classified as informational and helps provide context for interpreting automated scan limitations.

Proof of Concept





Conclusion

No high-risk vulnerabilities were identified during this assessment; however, the medium and low-risk findings should be addressed to strengthen the application's overall posture. Implementing the recommended improvements will enhance resilience and support adherence to security best practices.